Cryptographic Bill of Materials (CBOM)

Automated NIST FIPS 203/204/205 Quantum Risk & Migration Roadmap

TARGET ASSET	**SCAN CLASSIFICATION**
www.demo-bank.example	Active Ingress TLS & Protocol Diagnostic
ASSESSED FOR	**EVALUATION DATE**
Executive Director · Demo Bank Corp	22/10/2026, 02:15:11

Quantum Readiness Score & HNDL Risk

31 /100

High quantum exposure

18 of 23 identified cryptographic primitives are breakable by Shor's algorithm, 4 are weakened under Grover search, and 3 hold today. Evaluated across a 12-year data retention horizon.

MOSCA THEOREM · HNDL HORIZON

INEQUALITY: (X + Y) > Z [EXPOSURE ACTIVE NOW]

- X (Data Shelf Life): 12 Years confidentiality requirement (financial, transactional, and identity records).
- Y (Migration Window): 3–4 Years required for end-to-end estate PKI, HSM, and protocol migration.
- Z (Quantum Threshold): ~6–7 Years until Cryptographically Relevant Quantum Computers (CRQCs) materialize (2030–2032).
- Harvest-Now-Decrypt-Later (HNDL): 16 Years > 7 Years. Enterprise traffic intercepted today will be decrypted prior to shelf-life expiration.

Executive Summary

This assessment compiles a complete cryptographic inventory of the target system and classifies every active primitive against post-quantum standards standardized by NIST (FIPS 203, 204, 205). Asymmetric cryptography (including RSA, ECDSA, ECDH, and classical Diffie-Hellman) will be completely broken once Cryptographically Relevant Quantum Computers (CRQCs) reach scale. Symmetric ciphers and hash functions experience effective security halving and require parameter expansion.

The imminent threat is Harvest-Now-Decrypt-Later (HNDL): adversaries actively capture encrypted enterprise traffic today to retroactively decrypt it once Shor’s algorithm is operational. Data with an operational life beyond 2029 is already in jeopardy. Migration sequencing must therefore be governed by data longevity rather than legacy system criticality.

Cryptographic Bill of Materials (CBOM)

Asset Name	Active Primitive	Security Purpose	Verdict	Recommended Move
TLS 1.3	TLS 1.3 / TLS 1.2 Handshake	Transport security	Broken (Shor)	ML-KEM-768 / X25519MLKEM768 (FIPS 203)
TLS 1.2	TLS 1.3 / TLS 1.2 Handshake	Transport security	Broken (Shor)	ML-KEM-768 / X25519MLKEM768 (FIPS 203)
x25519	CURVE25519 (ECDH)	TLS session key establishment	Broken (Shor)	Offer X25519MLKEM768 ahead of this group so recorded sessions stay safe.
secp256r1	P-256 (ECDH)	TLS session key establishment	Broken (Shor)	Offer X25519MLKEM768 ahead of this group so recorded sessions stay safe.
secp384r1	P-384 (ECDH)	TLS session key establishment	Broken (Shor)	Offer X25519MLKEM768 ahead of this group so recorded sessions stay safe.
AES-128-GCM	AES (128-bit)	TLS payload encryption	Weakened (Grover)	Prefer AES-256-GCM in the server's suite order.
AES-256-GCM	AES (256-bit)	TLS payload encryption	Quantum-Safe	Compliant under NIST / CNSA 2.0
ChaCha20-Poly1305	ChaCha20 (256-bit)	TLS payload encryption	Quantum-Safe	Compliant under NIST / CNSA 2.0
AES-128-CBC	AES (128-bit)	TLS payload encryption	Weakened (Grover)	Prefer AES-256-GCM in the server's suite order.
AES-256-CBC	AES (256-bit)	TLS payload encryption	Quantum-Safe	Compliant under NIST / CNSA 2.0
RSA key transport	RSAES-PKCS1	TLS 1.2 key exchange without forward secrecy	Broken (Shor)	Remove TLS_RSA_* suites; keep ECDHE only.
3DES-EDE-CBC	3DES (168-bit)	TLS payload encryption	Broken (Classical)	Remove 3DES suites.
RSA-2048	RSASSA-PKCS1 (2048-bit)	Certificate signature key (leaf)	Broken (Shor)	Migrate to ML-DSA-65 (FIPS 204) when your CA offers it; in the meantime keep RSA at 2048+ bits and automate renewal.

Plus 10 additional cryptographic assets mapped in the CycloneDX 1.6 export.

CRYPTOGRAPHIC INVENTORY ATTESTATION & AUDIT HASH
CBOM SHA-256 DIGEST: CDA054AD3F25BC3A0E5FA75B43E9212EA9F644853CD49B1B9B848060DF2E9CDE
CONFORMANCE: CycloneDX 1.6 Cryptography Extension · NIST IR 8547 · RFC 8446 / RFC 9180 Conformance

Enterprise Regulatory & Framework Alignment

Standard / Authority	Mandate Scope	Impact on Assessed Architecture	Compliance Status
NIST PQC Standards FIPS 203 / 204 / 205	ML-KEM, ML-DSA & SLH-DSA	Legacy RSA/ECDH key establishment and ECDSA signatures require systematic deprecation.	Action Required
NSA CNSA 2.0 National Security Memo 10	Commercial PQC Suite	Software and client communications must support hybrid/post-quantum cryptography by 2025–2030.	Non-Compliant
RBI Master Directions Cyber Security Framework	Cryptographic Governance	Directs scheduled cipher agility, inventory tracking, and avoidance of broken algorithms.	Audit Flag
SEBI Advisory Quantum Preparedness	Securities & Market Infra	Requires financial entities to map asymmetric crypto dependencies and formulate migration plans.	Plan Needed
EU DORA (Art. 9/10) Digital Resilience Act	ICT Cryptographic Resiliency	Continuous cryptographic bill of materials (CBOM) tracking and migration resilience required.	Attestation Rec.

Key Vulnerabilities & Remediation Actions

CRITICAL

Key exchange is classical only: recorded traffic can be decrypted later

Every session to www.demo-bank.example is protected by classical ECDH or RSA key exchange. An adversary who records this traffic today can decrypt it once a cryptographically relevant quantum computer exists (harvest now, decrypt later). With a 12-year data horizon, this is the first thing to fix.

Action: Enable hybrid X25519MLKEM768 key exchange at the TLS termination point (CDN, load balancer or web server). Browsers already offer it, so no client change is needed. [Standard: NIST FIPS 203 (ML-KEM), NIST IR 8547 (draft): quantum-vulnerable public-key algorithms deprecated after 2030, disallowed after 2035, NIST SP 1800-38: migration to post-quantum cryptography]

HIGH

RSA key-transport suites accepted (no forward secrecy)

These suites encrypt the session key directly to the server's RSA key. Whoever obtains that key later, through a breach or a quantum computer, can decrypt every recorded session at once.

Action: Remove all TLS_RSA_WITH_* suites; allow ECDHE (and hybrid ML-KEM in TLS 1.3) only. [Standard: RFC 9325 / BCP 195: recommendations for secure use of TLS]

HIGH

Broken cipher suites accepted

The server still accepts suites that are weak without any quantum computer (3DES, RC4, DES, export-grade, NULL or anonymous).

Action: Remove these suites from the server configuration. [Standard: RFC 9325 / BCP 195: recommendations for secure use of TLS]

HIGH

DKIM key 'selector1' is RSA-1024

1024-bit RSA DKIM keys are within reach of well-funded attackers today, allowing forged signed mail.

Action: Rotate to a 2048-bit key. [Standard: NIST FIPS 203/204]

Four-Phase PQC Migration Roadmap

PHASE 1 · 0–3 MONTHS

Automated Discovery & Cryptographic Agility Baseline

Deploy automated CBOM discovery across all internet-facing APIs, ingress controllers, and code repositories. Establish cryptographic agility governance and algorithm deprecation policies.

PHASE 2 · 3–6 MONTHS

Dual-KEM Hybrid Key Exchange Rollout

Enable X25519MLKEM768 hybrid key encapsulation across edge ingress, reverse proxies, and load balancers. Protect data in transit immediately against Harvest-Now-Decrypt-Later (HNDL) attacks.

PHASE 3 · 6–12 MONTHS

PKI Hierarchy & Certificate Authority Transition

Deploy hybrid and post-quantum certificate authorities (ML-DSA-65 / FIPS 204). Rotate identity and TLS certificates across high-value core services and internal service meshes.

PHASE 4 · 12–24 MONTHS

Native Post-Quantum Operations & Full Deprecation

Transition to pure post-quantum algorithms across data-at-rest encryption, HSMs, and code signing. Completely disable classical RSA and ECC fallback options.

Engagement with UElement U92 Quantum

Vyu provides single-target cryptographic scanning. Estate-wide automated discovery, continuous CBOM monitoring, Hardware Security Module (HSM) migration, and crypto-agility implementation are delivered by UElement U92 Quantum, our dedicated post-quantum security practice.

To schedule an executive briefing, review technical migration sequencing, or initiate estate-wide CBOM discovery with our cryptographic engineering team, contact us at contact@uelement.co or call +91 7620690561.

U92 QUANTUM CRYPTOGRAPHIC PRACTICE · PRACTICE LEAD AUDIT ATTESTATION

Authorized Technical Lead: Dr. A. Joshi · Senior Cryptographic Architect · UElement Technologies
Validation Key Fingerprint: 4E92 C10F 8892 001B 77FA 65C4 · Cryptographic Hash Verified